System Architecture & Configuration Report

Scenario Name: "The Chatty Client"

Date: December 13, 2025

Network Segment: CTF-Lab (Isolated LAN - 10.0.0.0/8)

1. Network Topology & Asset Inventory

The environment consists of three Windows Server nodes representing a multi-domain Active Directory Forest and one Linux attacker node.

Hostname	Role	OS	IP Address	Domain	Notes
DC01	Root Domain Controller	Windows Server 2019	10.0.0.10	MEGA.LOCAL	**Forest Root.** The ultimate target.
DC02	Child Domain Controller	Windows Server 2019	10.1.0.10	SUB.MEGA.LOCAL	Controls the Child Domain. Hosts the file shares.
CL02-HR	Workstation	Windows Server 2019*	10.1.0.100	SUB.MEGA.LOCAL	Simulated Client. **Entry Point** for the attack.
Kali	Attacker Node	Kali Linux	10.0.0.5	N/A	External threat actor.

**Note: CL02-HR runs Windows Server 2019 but is configured to behave as a standard client workstation.*

2. User Credentials & Roles (CTF Scope)

These are the credentials discoverable during the engagement.

Username	Password	Privileges	Role in Attack Chain
SUB\hr_juniors	**!QAZ2wsx**	Local Admin (on CL02-HR)	**Initial Access.** Hash captured via Responder (LLMNR). Used to pivot to the workstation via WinRM.
SUB\helpdesk_guy	**P@ssw0rd**	Standard User (Read Access to Secure Shares)	**Lateral Movement.** Credentials found in a local text file on CL02-HR. Used to access restricted shares on DC02.
SUB\Administrator	**RootPass123!**	Domain Admin (Child)	**Privilege Escalation.** Credentials found inside a text file in the Secure_Docs share on DC02.
MEGA\Administrator	**RootPass123!**	Enterprise Admin (Root)	**Forest Dominance.** Credentials found in a "Recovery Key" file on the DC02 Desktop.

3. Vulnerability Configuration Map

The following misconfigurations were intentionally deployed to create the exploit path.

Vulnerability 1: LLMNR/NBT-NS Poisoning (Entry Point)

- **Host:** CL02-HR (10.1.0.100)

- **Configuration:** A Scheduled Task named **"Corporate Drive Map"** is configured to run **At Startup**.
- **Mechanism:** The task executes a PowerShell command trying to map a drive to a non-existent server (\\backup-server01).
    - *Command:* net use Z: \\backup-server01\files /user:SUB\hr_juniors !QAZ2wsx
- **Impact:** This forces the machine to broadcast LLMNR/NBT-NS queries looking for "backup-server01", allowing an attacker to poison the request and capture the Net-NTLMv2 hash for hr_juniors.

Vulnerability 2: Insecure Credential Storage (Local File)

- **Host:** CL02-HR (10.1.0.100)
- **Configuration:** A text file named **C:\hr_notes.txt** exists on the root of the C: drive.
- **Content:** Contains the plaintext credentials for the user helpdesk_guy.
- **Impact:** An attacker with Local Admin rights (gained via hr_juniors) can read this file to pivot to a new user account.

Vulnerability 3: Excessive Share Permissions (Information Disclosure)

- **Host:** DC02 (10.1.0.10)
- **Configuration:** A file share named **Secure_Docs** is configured with Read permissions for helpdesk_guy.
- **Content:** Contains 107 "User Agreement" text files. One specific file (User_Agreement_Admin_Recovery.txt) contains the **Domain Administrator** credentials.
- **Impact:** Allows a standard user (helpdesk_guy) to hunt for and discover administrative credentials.

Vulnerability 4: Password Reuse & Plaintext Secrets

- **Host:** DC02 (10.1.0.10)
- **Configuration:** A text file named **Forest_Recovery_Key.txt** is located on the Administrator desktop.
- **Content:** Contains the plaintext credentials for the **Root Domain** (MEGA\Administrator), which are identical to the Child Domain credentials (RootPass123!).
- **Impact:** Allows immediate escalation from Child Domain Admin to Enterprise Admin without requiring complex Kerberos attacks (Golden Ticket).

---

4. Attacker Machine Configuration

To successfully execute the attack, the Kali Linux machine requires the following configuration:

- **Static IP:** 10.0.0.5 (Netmask /8).

- **Network Adapter:** VMnet / LAN Segment set to "CTF-Lab".
- **DNS/Hosts File:** The /etc/hosts file must map the domain names to the DCs for tool compatibility (e.g., impacket-psexec).

Plaintext

```
10.0.0.10    dc01.mega.local mega.local MEGA.LOCAL
10.1.0.10    dc02.sub.mega.local sub.mega.local SUB.MEGA.LOCAL SUB
```